

Datenschutz-Folgenabschätzungen: Portal bAV

Grundangaben zum Unternehmen

Adresse und Kontaktdaten

Firma/Name	Musterfirma XY
Beschreibung	Zu unseren Dienstleistungen gehören die versicherungsmathematische Bewertung und Analyse von Versorgungssystemen z.B. für den Jahresabschluss. Außerdem unterstützen wir Unternehmen und ihre Mitarbeiter dabei, den komplexen Bereich der betrieblichen Altersversorgung zu verstehen und attraktive, neue Formen zu nutzen.
Straße, Nr., PLZ, Ort	Musterstr. 00 12345 IT-Stadt Deutschland
E-Mail	info@musterfirma.org
Telefon	+49 1234 5678
Homepage	https://www.musterfirma.org/

Verantwortlich für die Datenverarbeitung

Name	Verantwortlicher 1
Funktion	Geschäftsführender Gesellschafter
E-Mail	

Name	Verantwortlicher 2
Funktion	Geschäftsführende Gesellschafterin

Name	Verantwortlicher 3
Funktion	Geschäftsführende Gesellschafterin

Datenschutzbeauftragter

Firma	Datenschutzberatung Nord (für diese DSFA temporär beauftragter Dienstleister)
Name	Dirk Moltzen

Dokument: Portal bAV		
Klassifizierung: Intern	Stand: 16.04.2026	Seite: 1 von 14

Funktion	externer Datenschutzbeauftragter TÜV® CERT
Adresse	
E-Mail	
Telefon	

Erforderlichkeitsprüfung

Geplante Verarbeitung	Betrieb eines Portals zur betrieblichen Altersvorsorge
Ergebnis der Erforderlichkeitsprüfung	Eine Datenschutz-Folgenabschätzung ist notwendig.
Erläuterung	Im Rahmen einer Qualitätsmanagement-Zertifizierung wurde das Portal auf Informationssicherheit bewertet (BIA) und eine DSFA als notwendig angesehen. Die Geschäftsführung hat die Durchführung einer DSFA in Auftrag gegeben, um den Schutz der Persönlichkeitsrechte der Betroffenen zu bewerten und ggf. anzupassen.

Informationen zur DSFA

Allgemeine Beschreibung der Datenschutz-Folgenabschätzungen

Die DSFA wird für ein firmeneigenes bAV-Portal durchgeführt, um festzustellen wie die Risiken für personenbezogene Daten einzuordnen sind. Kann das Portal mit den derzeitigen technisch-organisatorischen Maßnahmen betrieben werden oder müssen höhere Schutzstufen erreicht werden? Wir nutzen zur Orientierung die Entscheidungshilfen der Datenschutzkonferenz (DSK) der unabhängigen Aufsichtsbehörden des Bundes und der Länder, sowie die bereits durchgeführte Business Impact Analysis (BIA) die durch die ABC Group erfolgt ist.

Als durchführender DSB wurde die Datenschutzberatung Nord als externer Dienstleister beauftragt. Die Datenschutzberatung Nord ist zum Zeitpunkt der DSFA kein bestellter DSB der Musterfirma XY.

Systematische Beschreibung der Verarbeitung

Geplante Verarbeitung	Betrieb eines Portals zur betrieblichen Altersvorsorge
Verantwortliche Abteilung	IT-Abteilung
Beschreibung	Ein Portal für betriebliche Altersversorgung (bAV) dient als digitale, webbasierte Plattform, um die Verwaltung, Kommunikation und Transparenz der betrieblichen Altersvorsorge zwischen Arbeitgebern und Arbeitnehmern zu vereinfachen. Es fungiert als zentrale Anlaufstelle, die Prozesse digitalisiert und effizienter gestaltet.
Zwecke der Datenverarbeitung	Plattform-basierte Bereitstellung von Daten zur betrieblichen Altersvorsorge

Dokument: Portal bAV

Klassifizierung: Intern

Stand: 16.04.2026

Seite: 2 von 14

Zweckbeschreibung	Reduzierung des Verwaltungsaufwands: Personalabteilungen (HR) werden durch automatisierte Vertragsverwaltung und digitale Prozesse (z.B. Datenaustausch mit Versicherern) entlastet. Transparenz und Information: Mitarbeiter erhalten jederzeit Zugriff auf ihre individuellen Vertragsdaten, wie ein virtuelles Versorgungskonto oder den Vertragsordner. Selbstbedienung (Self-Service) für Mitarbeitende: Versicherte können Rentenlücken ermitteln, Angebote berechnen und Nettoaufwand kalkulieren. Datensicherheit und Compliance: Die Plattform ermöglicht ein DSGVO-konformes Datenmanagement, was besonders bei der Übermittlung personenbezogener Daten an Versicherer wichtig ist. Arbeitgeberattraktivität: Durch eine moderne, digitale Verwaltung der Sozialleistungen (bAV) steigern Unternehmen ihre Attraktivität und binden Fachkräfte. Rechtssicherheit: Die Portale unterstützen bei der Einhaltung von Dokumentationspflichten, insbesondere bei Arbeits-, Steuer- und Sozialversicherungsrecht.
Art der Daten / Datenkategorien	• Bestandsdaten (Namen, Adressen) • Kontaktdaten (E-Mail, Telefonnummern, Fax, Messenger) • Vertragsdaten (Zeitpunkt, Inhalt, Zahlungsinformationen, Kundenkategorie, Bonitätsdaten) • Beschäftigtenstammdaten (Namen, Adressen, Lohngruppe, Steuermerkmale)
Besondere Datenkategorien Art. 9 DSGVO	Daten mit sensiblem Charakter (Rentendaten) die nicht unter Art. 9 DSGVO fallen.
Kreis/Kategorie betroffener Personengruppen	• Partnerunternehmen und deren Mitarbeiter • Beschäftigte
Quellen der Daten	• Freiwillige Selbstangaben • Vertragsdaten • Erhoben beim Betroffenen
Art der Verarbeitung	Elektronische Verarbeitung
Applikationen	Portal bAV
Involvierte Systeme und Geräte	Server des Unternehmens
Rechtsgrundlagen der Verarbeitung	• Beschäftigungsverhältnis (§ 26 BDSG i.V.m. Art. 88 DSGVO) • Vertragserfüllung (Art. 6 Abs. 1 lit. b DSGVO)
Informationen zur Rechtsgrundlage	Vertragliche Regelung zur betrieblichen Altersvorsorge zwischen Arbeitnehmer und Arbeitgeber
Empfänger intern	• IT-Abteilung

Dokument: Portal bAV		
Klassifizierung: Intern	Stand: 16.04.2026	Seite: 3 von 14

	• Berater
Dritter	Musterfirma XY (Deutschland)
Übermittlung/Offenlegung gegenüber sonstigen Dritten	• Banken • Steuerberater • Sozialversicherungsträger
Datenübermittlung an ein Drittland Art. 30 Abs. 1 S. 2 lit. e	Datenübermittlung an ein Drittland oder an eine internationale Organisation findet nicht statt und ist auch nicht geplant.
Spezielle Sicherheitsmaßnahmen	Verschlüsselung, Backup-Management, Redundanzsystem, Berechtigungskonzept, Passwortschutz mit MFA-Koppelung, ISO/IEC 27001-zertifizierte Rechenzentren in Deutschland
Systembeschreibung	Portale
Wie werden die Betroffenen informiert	Belehrung bei Vertragsabschluss im Unternehmen des Auftraggebers
DS-Folgenabschätzung erforderlich	Ja
Erläuterung	Im Rahmen einer Qualitätsmanagement-Zertifizierung wurde das Portal auf Informationssicherheit bewertet (BIA) und eine DSFA als notwendig angesehen. Die Geschäftsführung hat die Durchführung einer DSFA in Auftrag gegeben, um den Schutz der Persönlichkeitsrechte der Betroffenen zu bewerten und ggf. anzupassen.
Löschprozess	Bestandsdaten, Kontaktdaten, Vertragsdaten, Beschäftigtenstammdaten, Daten mit sensiblem Charakter (Rentendaten) die nicht unter Art. 9 DSGVO fallen.
Betroffene Datenkategorien	• Bestandsdaten (Namen, Adressen) • Kontaktdaten (E-Mail, Telefonnummern, Fax, Messenger) • Vertragsdaten (Zeitpunkt, Inhalt, Zahlungsinformationen, Kundenkategorie, Bonitätsdaten) • Beschäftigtenstammdaten (Namen, Adressen, Lohngruppe, Steuermerkmale) • Daten mit sensiblem Charakter (Rentendaten) die nicht unter Art. 9 DSGVO fallen.
Aufbewahrungsrechte und -pflichten	• Geldwäscheprävention, 10 Jahre Aufbewahrungspflicht (§ 8 GwG) • Dokumente betriebliche Altersversorgung, 30 Jahre Aufbewahrungspflicht (§ 18 a BetrAVG) • Aufbewahrungsrecht: Einwilligung im Beschäftigungsverhältnis (Art. 6 Abs. 1 lit. a DSGVO i.V.m. § 26 Abs. 2 BDSG)
Löschfristen	Löschung mit Ende gesetzliche Aufbewahrungspflicht
Zuständige Abteilung für die Löschung	Unternehmensführung

Dokument: Portal bAV		
Klassifizierung: Intern	Stand: 16.04.2026	Seite: 4 von 14

Spezielle Maßnahmen zur Löschung	DIN 66399 bzw. ISO/IEC 27555
Wie wird die Löschung dokumentiert?	Systemseitige Protokollierung
Wie wird die Löschung kontrolliert?	Anlassbezogene stichprobenartige Kontrolle
Art der Löschung	automatisiert
Sonstige Erläuterungen zum Löschprozess	Vorherige Kontrolle durch Administratoren

Gibt es Normen, Standards oder Zertifizierungen für die Verarbeitung?

- ISO/IEC 27001:2022
- ISO 9001:2015 (in Umsetzung: Stand April 2026)
- in Umsetzung NIS2 und DORA (Stand April 2026)
- ISAE 3402 Typ II

Grundlegende Prinzipien

Verhältnismäßigkeit und Notwendigkeit

Sind die Verarbeitungszwecke eindeutig definiert und rechtmäßig?

Das Unternehmen Musterfirma XY hat diesen Verarbeitungszweck als Kernaufgabe definiert und führt diesen Verarbeitungszweck seit Jahrzehnten durch. Der Zweck ist legitim und die Rechtgrundlage der Verarbeitung von personenbezogenen Daten ergibt sich aus der vertraglichen Bindung zu Kunden und deren Beschäftigten. Die Umsetzung einer betrieblichen Altersvorsorge entspricht einer freiwilligen Teilnahme von Arbeitnehmer und Arbeitgeber.

Gibt es alternative Verfahrensmöglichkeiten?

Als Notbehelf kann diese Berechnung bzw. diese Bearbeitung per Tabellenkalkulationssoftware (wie Microsoft Excel) dargestellt und umgesetzt werden. Diese Variante ist aber sehr viel zeitintensiver und weniger effektiv als eine Portal-Lösung. Zudem ist die nicht permanent verfügbar und schwieriger aktuell zu halten.

Sind die erhobenen Daten erforderlich, relevant und auf das für die Datenverarbeitung Notwendige beschränkt?

Der Grundsatz der Datenminimierung gem. Art. 5 (1) lit. e DSGVO wird eingehalten und nur so viele Daten erhoben, wie für den Zweck der Berechnung einer Vorsorgerente erforderlich und notwendig ist.

Wie werden die Daten korrekt und auf dem neuesten Stand gehalten?

Die Daten werden vom Auftraggeber bereitgestellt und im Auftrag des Verantwortlichen verarbeitet. Die bereitgestellten Daten werden zuerst manuell gesichtet und vorbereitet. Anschließend erfolgt eine automatisierte Dateneinspielung, in Verbindung mit einer Plausibilitäts- und Strukturkontrolle.

Dokument: Portal bAV		
Klassifizierung: Intern	Stand: 16.04.2026	Seite: 5 von 14

Maßnahmen zum Schutz der Persönlichkeitsrechte

Wie werden die betroffenen Personen über die Verarbeitung informiert?

Die Information der Betroffenen erfolgt durch den Auftraggeber (Verantwortlichen). Ein Auftragsverarbeitungsvertrag ist mit dem Auftraggeber geschlossen worden.

Wie wird die Einwilligung eingeholt?

Da als Rechtmäßigkeit eine vertragliche Grundlage gem. Art. 6 (1) lit. b DSGVO vorliegt, ist eine Einwilligung zur Datenverarbeitung nicht notwendig. Für die Datenverarbeitung durch den beteiligten Arbeitgeber gilt der Art. 88 DSGVO i.V.m. § 26 BDSG als Rechtsgrundlage für die Datenverarbeitung der relevanten Arbeitnehmerdaten, sowie für deren Übertragung.

Wie können Betroffene ihre Rechte auf Auskunft und Datenübertragbarkeit ausüben?

Über Kontaktaufnahme zum DSB oder zum Verantwortlichen oder des Auftragsverarbeiters per E-Mail. Der Prozess wird dann über das Datenschutz-Management gesteuert und durchgeführt.

Wie können betroffene Personen ihre Rechte auf Berichtigung und Löschung ausüben?

Über Kontaktaufnahme zum DSB oder zum Verantwortlichen oder des Auftragsverarbeiters per E-Mail. Der Prozess wird dann über das Datenschutz-Management gesteuert und durchgeführt.

Wie können betroffene Personen ihre Rechte auf Einschränkung oder Widerspruch der Verarbeitung ausüben?

Über Kontaktaufnahme zum DSB oder zum Verantwortlichen oder des Auftragsverarbeiters per E-Mail. Der Prozess wird dann über das Datenschutz-Management gesteuert und durchgeführt.

Sind die Verpflichtungen der Auftragsverarbeiter klar definiert und vertraglich geregelt?

Ja, für das Rechenzentrum (Server) sind geprüfte AV-Verträge geschlossen worden.

Soweit Datenübermittlung in Länder außerhalb der EU stattfindet, werden die Daten angemessen geschützt?

Dieser Punkt entfällt, da keine Übertragung ins Ausland stattfindet und auch nicht geplant ist.

Geplante oder bestehende Maßnahmen

- Es werden nicht mehr personenbezogene Daten erhoben, als für den jeweiligen Zweck erforderlich sind
- Es liegt ein Verzeichnis von Verarbeitungstätigkeiten vor.
- Es wurde ein DSB (Datenschutzbeauftragter) benannt und an die Aufsichtsbehörde gemeldet.
- Es wurde ein ISB (Informationssicherheitsbeauftragter) benannt.
- Alle Mitarbeiter werden regelmäßig zum Datenschutz geschult (mindestens 1x jährlich). Neue Mitarbeiter erhalten eine Datenschutzeinweisung vor ihrer Arbeitsaufnahme.

Dokument: Portal bAV		
Klassifizierung: Intern	Stand: 16.04.2026	Seite: 6 von 14

- Alle Mitarbeiter kennen die Abläufe bei Datenpannen.
- Mitarbeiter werden im Hinblick auf den Datenschutz auf Verschwiegenheit verpflichtet, belehrt und instruiert, als auch auf mögliche Haftungsfolgen hingewiesen. Sofern Mitarbeiter außerhalb betriebsinterner Räumlichkeiten tätig werden oder Privatgeräte für betriebliche Tätigkeiten einsetzen, existieren spezielle Regelungen zum Schutz der Daten in diesen Konstellationen und der Sicherung der Rechte von Auftraggebern einer Auftragsverarbeitung.
- Der Schutz von personenbezogenen Daten wird unter Berücksichtigung des Stands der Technik, der Implementierungskosten und der Art, des Umfangs, der Umstände und der Zwecke der Verarbeitung sowie der unterschiedlichen Eintrittswahrscheinlichkeit und Schwere der mit der Verarbeitung verbundenen Risiken für die Rechte und Freiheiten natürlicher Personen bereits bei der Entwicklung, bzw. Auswahl von Hardware, Software sowie Verfahren, entsprechend dem Prinzip des Datenschutzes durch Technikgestaltung und durch datenschutzfreundliche Voreinstellungen berücksichtigt (Art. 25 DSGVO).
- Genutzte Software entspricht den Anforderungen nach Art. 25 DSGVO (privacy by design / default)
- Bei der Weitergabe von Daten wird die Rechtmäßigkeit eingehalten und erfolgt in dokumentierter Weise. Es werden, wenn erforderlich, Verträge zur Auftragsverarbeitung oder gemeinsamen Verantwortung geschlossen.
- Der DSB prüft regelmäßig unsere Auftragsverarbeiter und deren Verträge, sowie die TOMs zu dem AV-Vertrag.
- Die Verarbeitung von Daten wird größtmöglich auf die EU beschränkt.
- Serverraum ist zusätzlich gesichert. Zutritt haben nur berechtigte Personen (Admins, Geschäftsführung, etc.)
- Richtlinie zu Login- und Passwortregeln
- Passwörter werden verschlüsselt gespeichert.
- Authentifikation mit Benutzer und Passwort und bei erhöhtem Schutzbedarf durch eine zusätzliche Multifaktor-Authentisierung
- Protokollierung von Zugriffen auf Anwendungen, konkret bei der Eingabe, Änderung und Löschung von Daten
- Berechtigungs-/ Authentifizierungskonzepte mit auf Nötigste beschränkten Zugriffsregulierungen
- Stets aktueller Virenschutz für alle mobilen Geräte, Rechner und Server
- Einsatz von VPN-Technologie mit pre-shared Key (PSK)
- Physische Mandantentrennung (Hardware)
- Logische Mandantentrennung (Software)
- Trennung von Produktiv- und Testsystem
- Steuerung über Berechtigungskonzept

Dokument: Portal bAV		
Klassifizierung: Intern	Stand: 16.04.2026	Seite: 7 von 14

- Remote Zugriff nur verschlüsselt über VPN
- Mitarbeiter müssen mit ihrem eigenen Account arbeiten (keine Weitergabe von Passwörtern oder Login-Daten)
- Berechtigungskonzepte finden Anwendung für Software und geteilte Dateiordner
- Einsatz von RAID-Systemen
- Einsatz von Festplattenspiegelung
- Protokollierung bei Veränderung von Daten
- Täglich inkrementelle Sicherung und wöchentliche Komplettsicherung der Daten
- Ständig kontrolliertes Backup- und Recovery-Konzept (ausformuliertes Konzept)
- Regelmäßiges Testen einer Rücksicherung (Wiederherstellung von Daten) inklusive Protokollierung der Ergebnisse
- Dokumentation der Datenempfänger, der Speicherdauer, den Löschfristen im Verzeichnis der Verarbeitungstätigkeiten (VVT)
- Notfallkonzept
- Einsatz einer unterbrechungsfreien Stromversorgung und Überspannungsschutz der wichtigsten Systeme / des Servers
- Notfallpläne sind vorhanden (Feuer, Wasser, Stromausfall, Cyberangriff, etc.)
- Webseiten werden verschlüsselt betrieben
- Protokollierung von Dateneingaben-, Änderungen und Löschungen
- Vergabe von Rechten zur Eingabe, Änderung und Löschung von Daten auf Basis eines Berechtigungskonzepts
- Jeder Mitarbeiter nutzt einen eigenen Account. Die Weitergabe oder gemeinsame Nutzung von Accounts bzw. deren Passwörter findet keine Anwendung.
- Vorherige Prüfung der vom Auftragnehmer (AV) getroffenen TOM und deren Dokumentation (durch DSB oder Verantwortlichen)
- Abschluss der notwendigen Vereinbarung zur Auftragsverarbeitung bzw. EU-Standarddatenschutz-Vertragsklauseln
- Verpflichtung der Mitarbeiter des Auftragsverarbeiters auf die Vertraulichkeit gem. Art. 28 (3) lit. b DSGVO
- Regelung zum Einsatz weiterer Subunternehmer im AVV wurde festgelegt
- Auswahl von Auftragnehmern unter Sorgfaltsgesichtspunkten in Bezug auf Datenschutz und -sicherheit)
- Schriftliche Festlegung der Weisungen an den Auftragnehmer

Dokument: Portal bAV		
Klassifizierung: Intern	Stand: 16.04.2026	Seite: 8 von 14

- Bei längerer Zusammenarbeit: DSB prüft regelmäßig den Auftragsverarbeiter und sein Schutzniveau (Nachkontrollen)
- Vereinbarungen von wirksamen Kontrollrechten gegenüber Auftragnehmern
- Eindeutige Vertragsgestaltung (AVV / RAVV) wird sichergestellt
- Sicherstellung der Vernichtung von Daten nach Beendigung des Auftrags
- Datenweitergabe an Dritte nur auf dokumentierte Weise (geschlossener AVV)
- Einsatz eines Datenschutz-Management-Systems DSMS (z.B. SaaS)
- Zentrale Dokumentation aller Verfahrensweisen und Regelungen zum Datenschutz mit Zugriff für alle Mitarbeiter nach Bedarf / Berechtigung (auch die entsprechenden Zugangsdaten für eine SaaS Lösung)
- Wirksamkeitsprüfung der TOMs wird min. jährlich durchgeführt
- Es wurde ein DSB benannt und die Kontaktdaten sind veröffentlicht
- Die Einbindung eines DSB zu Datenschutzfragen wird umgesetzt
- Es wurde ein ISB benannt und die Kontaktdaten veröffentlicht
- Die Einbindung eines ISB bei Sicherheitsfragen wird umgesetzt
- Sensibilisierungen und Schulungen der Mitarbeiter zum Datenschutz finden regelmäßig statt (mindestens jährlich, dokumentiert)
- Leit- und Richtlinien zur Informationssicherheit und dem Datenschutz sind definiert und von der Geschäftsführung genehmigt, sowie den Mitarbeitern eröffnet worden
- Rollen und Verantwortlichkeiten im Bereich der Sicherheit und im Datenschutz sind im eigenen Betrieb bekannt und besetzt
- Mitarbeiter werden in dokumentierter Weise zur Vertraulichkeit / Geheimhaltung verpflichtet (das bezieht sich auch auf den Onboarding-Prozess neuer Mitarbeiter vor Arbeitsaufnahme)
- Das Datenschutz-Managementsystem stellt eine kontrollierte Bearbeitung von Anfragen Betroffener sicher. Die Einhaltung von Fristen wird durch das System überwacht und an Verantwortliche gemeldet.
- Die Organisation / das Unternehmen kommt den Informationspflichten nach Art. 13 und 14 nach
- Einsatz von Firewall mit regelmäßiger Aktualisierung
- Einsatz von Spamfilter mit regelmäßiger Aktualisierung
- Einsatz von Virens Scanner mit regelmäßiger Aktualisierung
- Einsatz von Intrusion-Detection-System (IDS)
- Einsatz von Intrusion-Prevention-System (IPS)

Dokument: Portal bAV		
Klassifizierung: Intern	Stand: 16.04.2026	Seite: 9 von 14

- Dokumentierter Prozess zur Erkennung und Meldung von Sicherheitsvorfällen Datenpannen (auch im Hinblick auf Meldepflichten gegenüber Aufsichtsbehörden)
- Dokumentierte Vorgehensweise zum Umgang mit Sicherheitsvorfällen
- Einbindung von DSB bei Datenpannen oder Betroffenenanfragen oder Anfragen der Aufsichtsbehörden
- Einbindung des ISB bei Sicherheitsvorfällen
- Dokumentation von Sicherheitsvorfällen und Datenpannen via Ticketsystem oder DSMS
- Formaler Prozess und Verantwortlichkeiten zur Nachbearbeitung von Sicherheitsvorfällen und Datenpannen (wie PDCA-Zyklus, QM, KVP, o.ä.)
- Vollständige Dokumentation manueller Notverfahren inkl. Nachpflegeprozess
- Lückenlose Protokollierung aller manuellen Änderungen, insbesondere im Außendienst
- Protokolle werden geprüft (manuell oder automatisiert)
- Sonder-Logging für fachkritische Objekte
- Eigenbetrieb in zwei RZs mit redundanter, identischer Hardware im zweiten RZ für die Verfügbarkeit des Portals (bAV)
- Anwendung von ZFS Snapshots (schreibgeschützte Kopie eines Dateisystems bzw. eines Volume)
- Durchführen von Replikationen
- Vollständige MFA-Pflicht für privilegierte Zugriffe
- Stichproben- / Kontrollmechanismen für manuelle Änderungen
- Formale Freigabe nach Abschluss der RACI-Matrix
- Formalisierte Trennung von Rollen und Nachweis der Segregation of Duties (SoD) / Funktionstrennung
- Qualitätssicherungsmaßnahme des 4-Augenprinzips wird bei Freigaben angewendet
- Umsetzung der Rechtevergabe nach dem "Need-To-Know-Prinzip" / Least Privilege
- Einsatz und Nutzung Multi-Faktor-Authentifizierung (MFA)
- Einführung, Verwaltung und Nutzung von segmentierten ADMIN-Rechten
- Revisionssichere und vollständige Historisierung aller fachkritischen Änderungen
- Einsatz eines Security Information and Event Management-Systems (SIEM); Echtzeit-Analysen von Sicherheitswarnungen

Dokument: Portal bAV		
Klassifizierung: Intern	Stand: 16.04.2026	Seite: 10 von 14

Risikoszenarien

Szenario: Vertraulichkeit

Was können die wesentlichen Auswirkungen für die betroffenen Personen sein, wenn das Risiko eintritt?

- Identitätsdiebstahl, Identitätsbetrug
- Kontrollverlust über die eigenen Daten

Was sind die Hauptbedrohungen, die zu dem Risiko führen könnten?

- Sabotage
- Spionage

Was sind die Risikoquellen?

Externe menschliche Risikoquelle

Welche der identifizierten Maßnahmen tragen zur Bewältigung des Risikos bei?

- Vollständige MFA-Pflicht für privilegierte Zugriffe
- Stichproben- / Kontrollmechanismen für manuelle Änderungen
- Formale Freigabe nach Abschluss der RACI-Matrix
- Formalisierte Trennung von Rollen und Nachweis der Segregation of Duties (SoD) / Funktionstrennung
- Qualitätssicherungsmaßnahme des 4-Augenprinzips wird bei Freigaben angewendet
- Umsetzung der Rechtevergabe nach dem "Need-To-Know-Prinzip" / Least Privilege
- Einsatz und Nutzung Multi-Faktor-Authentifizierung (MFA)
- Einführung, Verwaltung und Nutzung von segmentierten ADMIN-Rechten

Einschätzung des Risikoschweregrads

überschaubar (3/5)

Einschätzung der Eintrittswahrscheinlichkeit

unwahrscheinlich (2/5)

Dokument: Portal bAV		
Klassifizierung: Intern	Stand: 16.04.2026	Seite: 11 von 14

Szenario: Verfügbarkeit

Was können die wesentlichen Auswirkungen für die betroffenen Personen sein, wenn das Risiko eintritt?

- Identitätsdiebstahl, Identitätsbetrug
- Kontrollverlust über die eigenen Daten

Was sind die Hauptbedrohungen, die zu dem Risiko führen könnten?

- Sabotage
- Spionage

Was sind die Risikoquellen?

Externe menschliche Risikoquelle

Welche der identifizierten Maßnahmen tragen zur Bewältigung des Risikos bei?

- Eigenbetrieb in zwei RZs mit redundanter, identischer Hardware im zweiten RZ für die Verfügbarkeit des Portals (bAV)
- Anwendung von ZFS Snapshots (schreibgeschützte Kopie eines Dateisystems bzw. eines Volume)
- Durchführen von Replikationen

Einschätzung des Risikoschweregrads

überschaubar (3/5)

Einschätzung der Eintrittswahrscheinlichkeit

unwahrscheinlich (2/5)

Szenario: Integrität

Was können die wesentlichen Auswirkungen für die betroffenen Personen sein, wenn das Risiko eintritt?

- Identitätsdiebstahl, Identitätsbetrug
- Aufhebung der Pseudonymisierung und Verlust der Vertraulichkeit

Was sind die Hauptbedrohungen, die zu dem Risiko führen könnten?

- Sabotage
- Spionage

Was sind die Risikoquellen?

Externe menschliche Risikoquelle

Dokument: Portal bAV		
Klassifizierung: Intern	Stand: 16.04.2026	Seite: 12 von 14

Welche der identifizierten Maßnahmen tragen zur Bewältigung des Risikos bei?

- Lückenlose Protokollierung aller manuellen Änderungen, insbesondere im Außendienst
- Sonder-Logging für fachkritische Objekte
- Revisionssichere und vollständige Historisierung aller fachkritischen Änderungen
- Einsatz eines Security Information and Event Management-Systems (SIEM); Echtzeit-Analysen von Sicherheitswarnungen

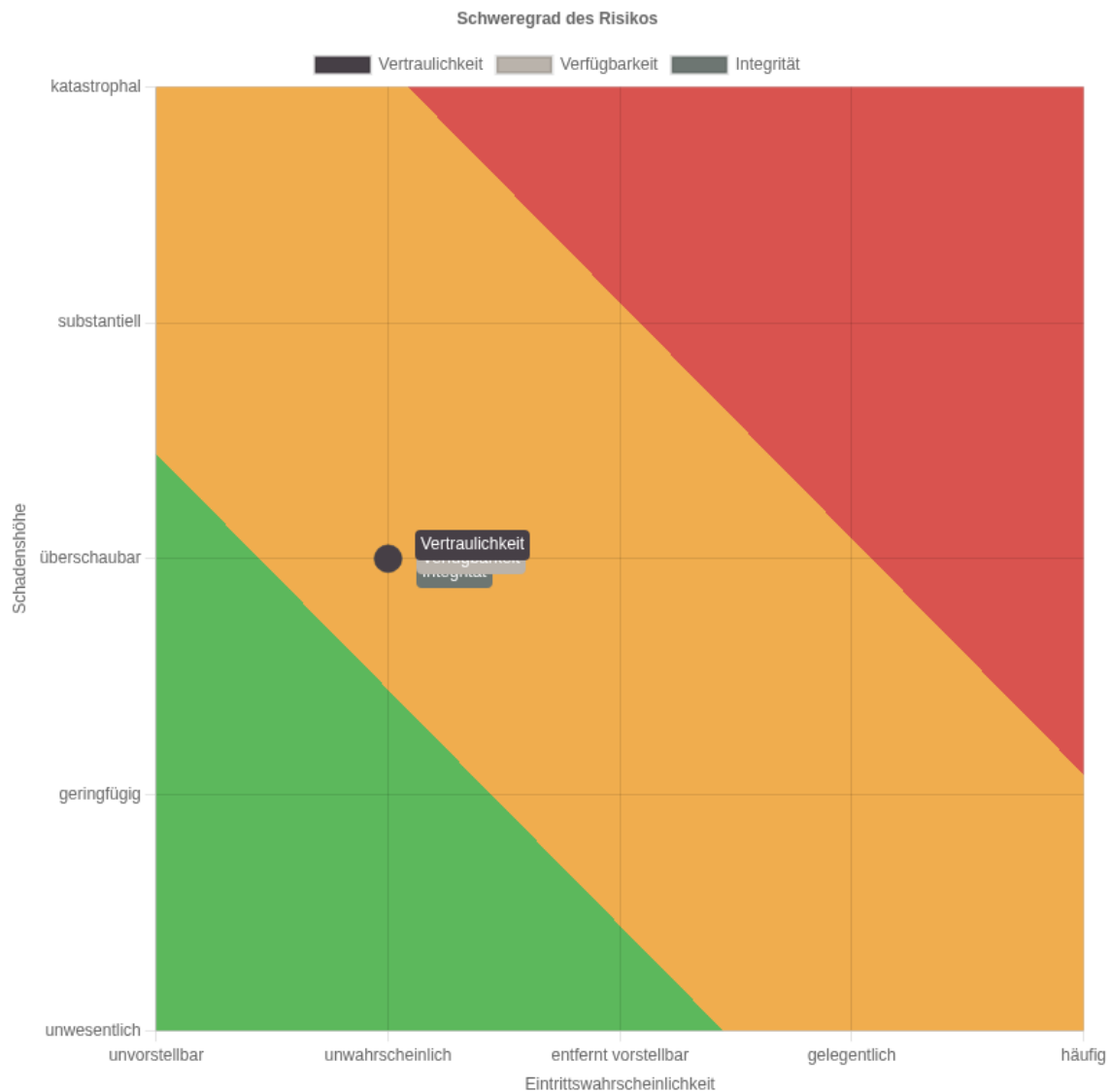
Einschätzung des Risikoschweregrads

überschaubar (3/5)

Einschätzung der Eintrittswahrscheinlichkeit

unwahrscheinlich (2/5)

Risikokartierung



Stellungnahmen

Stellungnahme des Datenschutzbeauftragten

Die technische Absicherung des zu bewertenden Portals und die damit verbundene Datensicherheit kann in Bezug auf den Stand der Technik als exzellent angesehen werden. Der Aufwand der nach Maßgabe des Art. 32 DSGVO (Sicherheit der Verarbeitung) steht weit über dem Verhältnismäßigkeitsgrundsatzes und zeigt sehr deutlich, dass die Datensicherheit, sowie auch der Schutz der Persönlichkeitsrechte für das Unternehmen an oberster Stelle stehen.

Auch wenn ein überschaubares Restrisiko besteht, ist die Eintrittswahrscheinlichkeit als eher gering anzusehen. Der hoch-aufgebaute Schutz und die erstellten Redundanzen, sowie die damit verbundenen und umgesetzten organisatorisch-technischen Maßnahmen, begründen eine Unbedenklichkeit von meiner Seite für den Betrieb des bAV-Portals, aus Sicht des Datenschutzes.

Einholung der Meinung der Betroffenen

Die Meinung der Betroffenen wurde nicht eingeholt.

Grund, warum die Meinung der Betroffenen nicht erfragt wurde

Es wurde keine Stellungnahme Betroffener eingeholt, da es keine Datenschutzverletzungen in der Vergangenheit gegeben hat. Die DSFA wurde aus den oben genannten Gründen gewählt und bezieht sich nicht auf die Verletzung personenbezogener Daten natürlicher Personen.

Konsultation der Aufsichtsbehörde

Die zuständige Aufsichtsbehörde wurde nicht konsultiert.

Erläuterung

Nein, eine Notwendigkeit der Konsultation der zuständigen Aufsichtsbehörde nach Art. 36 (1) DSGVO bestand zu keiner Zeit und ist aus Sicht des beauftragten DSB auch nicht erforderlich, da kein hohes Risiko für die Rechte und Freiheiten natürlicher Personen besteht oder bestanden hat.

Bestätigung

Datum	Name, Unterschrift, DSB
Datum	Name, Unterschrift, GF1
Datum	Name, Unterschrift, GF 2
Datum	Name, Unterschrift, GF 3

Dokument: Portal bAV		
Klassifizierung: Intern	Stand: 16.04.2026	Seite: 14 von 14